

Zero Trust im Swiss HDS

Umsetzung der Zero Trust Prinzipien im Swiss HDS

Autor: Martin Smock

Projekt: DigiSanté Architektur

Ausgabe: 0.3

Datum: 16. September 2025

Inhalt

1	EINFÜHRUNG UND ZIELE.....	3
1.1	AUFGABENSTELLUNG.....	3
1.1.1	<i>Einführung</i>	3
1.1.2	<i>Zero Trust Prinzipien</i>	4
1.1.3	<i>Umsetzungsfelder.....</i>	4
1.1.4	<i>Umsetzungsstrategien.....</i>	4
1.1.5	<i>Control, Data and Management Planes</i>	5
1.2	ABGRENZUNG	7
1.3	QUALITÄTSZIELE	8
1.4	STAKEHOLDER.....	8
1.5	TYPISCHE ABLÄUFE	9
1.5.1	<i>Authentisierung von Benutzern</i>	9
1.5.2	<i>Autorisierung von Zugriffen</i>	9
1.5.3	<i>Zugriffsentscheide.....</i>	9
1.5.4	<i>Rechtskonforme Protokollierung</i>	10
2	RANDBEDINGUNGEN	11
3	KONTEXTABGRENZUNG	12
4	LÖSUNGSSTRATEGIE	13
5	BAUSTEINSICHT	14
5.1.1	<i>Policy Information Point (PIP).....</i>	14
5.1.2	<i>Offene Fragen</i>	15
6	LAUFZEITSICHT	16
7	VERTEILUNGSSICHT	18
8	QUERSCHNITT KONZEPTE.....	18
9	ARCHITEKTURENTSCHEIDE	18
10	QUALITÄTSANFORDERUNGEN.....	18
10.1	QUALITÄTSBAUM	18
10.2	QUALITÄTSSZENARIEN	18
10.3	RISIKEN UND TECHNISCHE SCHULDEN	18
11	GLOSSAR.....	19
12	ANHANG	21
12.1	RISIKOABSCHÄTZUNG	21
12.1.1	<i>DOS Angriffe.....</i>	21
12.1.2	<i>Phishing.....</i>	21
12.1.3	<i>Ransomware</i>	22
12.1.4	<i>Replay Angriffe.....</i>	22
12.1.5	<i>OAuth Angriffe</i>	23
12.2	XACML REFERENZARCHITEKTUR.....	23

1 Einführung und Ziele

1.1 Aufgabenstellung

1.1.1 Einführung

Im Rahmen des DigiSanté Programms soll eine nationale Service Infrastruktur für den Swiss HDS aufgebaut werden. Die nationale Infrastruktur soll Services bereitstellen, welche für den Betrieb des Swiss HDS benötigt werden und nicht von den Teilnehmern selbst bereitgestellt werden können.

Zur Erfüllung der Anforderungen an den Datenschutz und die Datensicherheit sollen im Swiss HDS die Zero Trust Prinzipien umgesetzt werden, welche aktuell als de facto Standard für Datenschutz und Datensicherheit gelten.

Bis zum Aufkommen von Zero Trust wurde die Sicherheit mehrheitlich nach einem Perimeter Schutzmodell umgesetzt. Bei dem Perimeter Schutzmodell werden Netzwerkzonen, in denen die Applikationen betrieben werden, in unterschiedliche Vertrauensstufen eingeordnet und risikobasiert abgesichert.

Eine typische Unterteilung der Zonen in einem Schutzmodell mit Perimetern ist:

- Internetzone – Die Internetzone umfasst alle Netzwerke des öffentlichen Internets.
- DMZ – Vermittelndes Netz zwischen dem Internet und dem privaten Netzwerk. Zugriffe aus der DMZ auf das private Netz gilt als sicher, wenn die zugreifende Applikation oder der Benutzer authentisiert und für den Zugriff autorisiert ist.
- Privates Netzwerk – Zugriffe aus dem privaten Netz auf andere Applikationen und Services gelten grundsätzlich als sicher.

Zugriffe auf das Private Netzwerk nutzen dabei typisch X.509 Zertifikate, API Keys oder andere Methoden, welche von der DMZ und dem privaten Netzwerk unterstützt werden.

Das Schutzmodell nach Perimetern hat sich als anfällig für Attacken herausgestellt und ist in den vergangenen Jahren zunehmend in die Kritik geraten. Im Schutzmodell mit Perimetern kennen die Services im Privaten Netzwerk die Identität der Benutzer nicht und Zugriffe werden typischerweise auf der Basis von Rollen autorisiert.

Gelingt es einem Angreifer in die DMZ oder dem privaten Netzwerk einzudringen, kann ein Angreifer potenziell auf alle Services im Privaten Netz zugreifen. Spektakuläre Angriffe haben diese Möglichkeit in den vergangenen Jahren immer wieder ausgenutzt. Infrastrukturen mit einem Perimeter Schutzmodell gelten daher nicht mehr als sicher auf dem aktuellen Stand der Technik.

Als Reaktion auf die Schwächen des Perimeter Modells wurden die Zero Trust Prinzipien formuliert und haben sich mittlerweile auch international durchgesetzt.

In der Umsetzung der Zero Trust Prinzipien werden Netzwerkzonen nicht mehr als (alleiniger) Faktor für die Sicherheitseinstufung herangezogen. Die Identität des Benutzers bzw. der zugreifenden Applikation wird den Services bekannt gemacht und Zugriffsentscheidungen werden möglichst nahe an den Ressourcen, in den einzelnen Services und Applikationen durchgesetzt. Ergänzt wird das Konzept um Massnahmen zur Erkennung und Unterbindung von ungewöhnlichen Zugriffsmustern.

Dieses Dokument beschreibt einen Vorschlag für Massnahmen zur Umsetzung der Zero Trust Prinzipien im Swiss HDS. Dieses Dokument verweist dazu auf andere Dokumente und Spezifikationen, welche im Rahmen der Vorarbeiten erstellt wurden, insbesondere:

1. Swiss HDS IAM – Spezifikation für ein Identity und Access Management im Swiss HDS
2. Protokoll Service – Spezifikation für die rechtskonforme Protokollierung im Swiss HDS

1.1.2 Zero Trust Prinzipien

Das Zero Trust Security-Modell basiert auf mehreren grundlegenden Prinzipien:

- **Grundsätzliches Misstrauen gegenüber Zugriffen:** In einem Zero Trust-Netzwerk wird grundsätzlich keine Ressource und kein Zugriff auf schützenswerte Daten als vertrauenswürdig eingestuft. Grundsätzlich können alle Benutzer, Geräte und Anwendungen kompromittiert sein und potenzielle Angriffe Dritter auf die schützenswerten Ressourcen ausführen.
- **Minimierung von Berechtigungen:** Benutzer und Geräte erhalten nur die minimal erforderlichen Zugriffsrechte, um ihre Aufgaben zu erfüllen.
- **Zero Trust Access:** Der Zugriff auf Ressourcen erfolgt auf Basis strenger Authentifizierung und Autorisierung, mit denen jeder Zugriffsversuch überprüft wird. Zugriffsberechtigungen basieren auf präzisen Informationen zur Identität und Rolle des Benutzers, sowie einer dynamischen Bewertung von Umgebung bzw. dem Kontext zu gewähren.
- **Kontinuierliche Überprüfung:** Die Identität und der Status von Benutzern und Geräten werden kontinuierlich überwacht und überprüft, auch während einer laufenden Sitzung. Dabei werden alle zur Verfügung stehenden Informationen genutzt.

1.1.3 Umsetzungsfelder

Die Zero Trust Security Prinzipien werden typisch mit Strategien in den folgenden Umsetzungsfeldern umgesetzt:

- **Identitäts- und Zugriffsmanagement (IAM):** Eine starke IAM-Struktur, um die Identität von Benutzern und Geräten zu verwalten und sicherzustellen, dass nur autorisierte Personen und Systeme auf Ressourcen zugreifen.
- **Mikrosegmentierung:** Unterteilung der Netzwerke in kleine, voneinander isolierte Segmente und Einschränkung des Datenverkehrs zwischen den Segmenten.
- **Mehrstufige Authentifizierung:** Die Verwendung von mehreren Authentifizierungsfaktoren, wie Passwörter, Tokens, etc. für Personen und Systeme.
- **Erkennung von Bedrohungen und Anomalien:** Eine kontinuierliche Überwachung des Netzwerkverkehrs, Erkennung ungewöhnlichen Verhaltens und deren Unterbindung.

1.1.4 Umsetzungsstrategien

Bei der Umsetzung einer Zero Trust Architektur werden typischerweise eine, oder eine Kombination der folgenden Strategien verfolgt:

1.1.4.1 Mikro Segmentierung

Im Ansatz der Mikro Segmentierung werden einzelne Ressourcen oder Gruppen von Ressourcen in einzelne Netzwerksegmente gruppiert, welche je mit einer Gateway-Sicherheitskomponente geschützt ist.

In dieser Strategie implementieren die Gateway-Komponenten einen Policy Enforcement Point (PEP), welche die Zugriffsrechte durchsetzen und damit den Zugriff auf die Ressourcen schützt und dynamisch Zugriff auf einzelnen Anfragen von einem Client, einer Anlage oder einem anderen Dienst erteilen oder verwehren.

Die Gewährung der Zugriffsrechte basiert auf den Zugriffsrechten, aber auch Informationen aus dem verwendeten Gerät, der Status der Anlage und Umgebungsfaktoren, welche von einem Software-Agenten über das Client System ermittelt werden.

Diese Strategie wird typisch in Netzwerkmodellen gewählt, in denen mit Geräten zugegriffen wird, welche von den Unternehmen kontrolliert und verwaltet werden.

1.1.4.2 Erweiterte Identitätssteuerung

Der Ansatz der erweiterten Identitätssteuerung nutzt die Identität der Akteure als die Schlüsselkomponente der Zugriffssteuerung. Dabei können weitere Faktoren in die gewährte Zugriffsberechtigung einbezogen werden, wie z. B. die Einschränkung von Zugriffen auf der Grundlage des Netzwerkstandorts oder der genutzten Applikation.

Diese Strategie wird typischerweise in offenen Netzwerkmodellen gewählt, in denen die Geräte der Benutzer über das Internet zugreifen können. Der Zugang wird dabei zunächst allen Geräten gewährt, aber der Zugriff auf die Ressourcen wird nur Identitäten mit den entsprechenden Zugriffsberechtigungen gewährt.

Die grundsätzliche Gewährung von Zugriffen hat einen Nachteil, dass böswillige Akteure versuchen könnten, das Netz auszukundschaften oder das Netz zu nutzen, um «Denial-of-Service Angriffe (DDOS) zu starten. Die Strategie beinhaltet daher immer auch Massnahmen zur Unterbindung von Angriffen.

1.1.5 Control, Data and Management Planes

Angelehnt an die Begriffe aus der klassischen Netzwerktechnik, hat sich im Zero Trust Umfeld die Unterteilung in Data Plane, Control Plane und Management Plane für die verschiedenen Aufgabenbereiche etabliert.

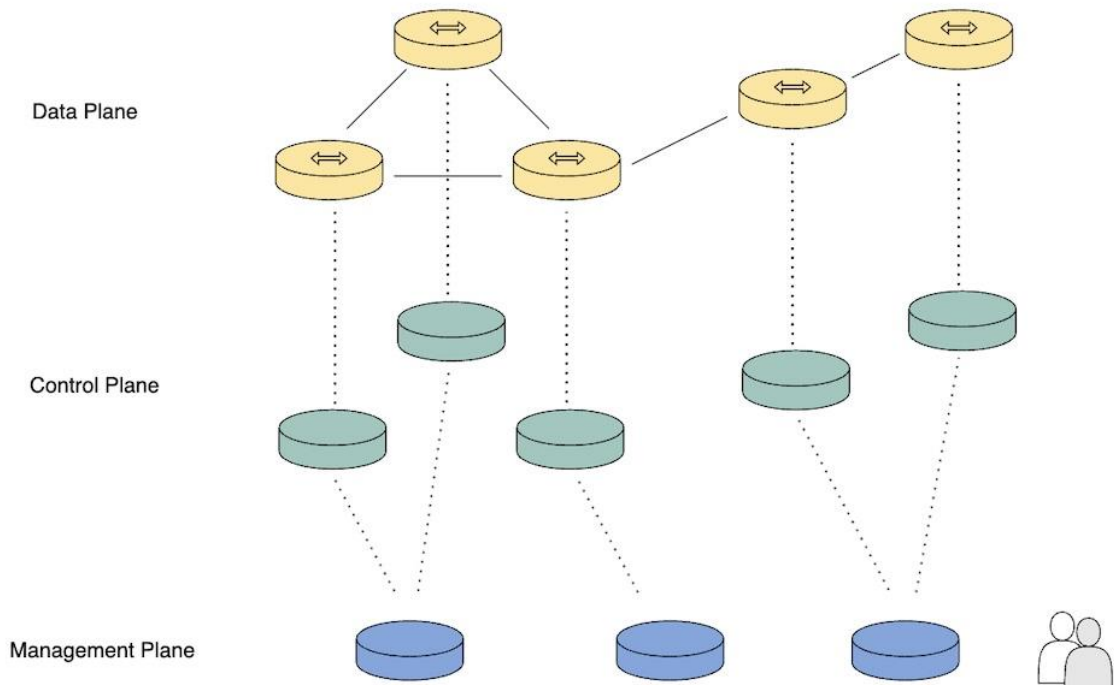


Abbildung 1: Ebenen einer Zero Trust Sicherheitsarchitektur

1.1.5.1 Data Plane

Die Data Plane bilden die fachlichen Services, welche Daten im Datenraum Gesundheit austauschen. Die fachlichen Services der Data Plane:

- Implementieren Schnittstellen für den Austausch von fachlichen Daten zwischen den Teilnehmern im Datenraum,
- Setzen die Zugriffsentscheide durch (Policy Enforcement),
- Protokollieren die Zugriffe¹,
- Nutzen dazu Schnittstellen zu den Services der Control Plane

Beispiele für Services auf der Data Plane im Swiss HDS sind:

- API der Datenbereitsteller,
- Client Systeme der Datennutzer bzw. Datenkonsumenten,
- Im Programm DigiSanté erstellten und betriebenen Fachservices.

¹ Gemeint ist hier die rechtskonforme Protokollierung gemäss Datenschutzgesetz. Andere Arten von Protokollen entstehen der Management Ebene (siehe unten).

- Im Programm DigiSanté erstellten und betriebenen Verzeichnisse und Register, wie z.B. der Terminologie Server.

1.1.5.2 Control Plane

Die Control Plane bilden die Services, welche die Datenflüsse im Datenraum steuern und kontrollieren. Die Services der Control Plane:

- Implementieren Schnittstellen für die Authentisierung, die Autorisierung und die Abfrage der Zugriffsentscheide,
- Implementieren Schnittstellen für die Protokollierung,
- Implementieren Schnittstellen zur Erkennung und Unterbindung von anormalem Verhalten und potentiellen Angriffen.

Beispiele für Services der Control Plane im Swiss HDS sind:

- Services für die Authentisierung und Autorisierung,
- Services zum Management und Durchsetzung der Zugriffsrechte,
- Services zur Protokollierung der Abfragen,
- Services zur Erkennung und Unterbindung von anormalem Verhalten und potentiellen Angriffen.

1.1.5.3 Management Plane

Die logische Ebene der Management Plane umfasst alle Dienstleistungen und Services zur Administration der Services der Control Plane.

Beispiele für Services der Management Plane im Swiss HDS sind:

- Cloud Services für den Betrieb der Services der Data und Control Plane,
- Dienstleistungen der Administratoren der Services der Control Plane,
- Protokollierung der Transaktionen auf der Netzwerkebene.

1.2 Abgrenzung

Dieses Dokument beschreibt die Umsetzung der Zero Trust Prinzipien auf der Data Plane und Control Plane. Grundsätzlich erstrecken sich die Prinzipien aber auch auf die Management Plane und regeln darin, wie die Zugriffe von Administratoren authentisiert, autorisiert und protokolliert und wie die Cloud Services gegen unbefugte Manipulation geschützt werden. Diese Massnahmen werden in einem separaten Dokument beschrieben.

Die Vorschläge für die Authentisierung, Autorisierung, Durchsetzung der Zugriffsrechte und Protokollierung wurden bereits in anderen Dokumenten² beschrieben. Die wichtigsten

² «Swiss HDS IAM – Spezifikation für ein Identity und Access Management im Swiss HDS» und «Protokoll Service – Spezifikation für die rechtskonforme Protokollierung im Swiss HDS»

Aspekte der darin beschriebenen Services werden in diesem Dokument zur Verbesserung der Lesbarkeit wiederholt.

Dieses Dokument konzentriert sich auf die Ergänzungen zum IAM, welche zur Erkennung von unautorisierten Zugriffen im Rahmen von Angriffen auf den SwissHDS benötigt werden (siehe Risikobetrachtung 12.1), insbesondere wie die dazu nötigen Daten erfasst und verfügbar gemacht werden. Die Details zur statistischen Auswertung der Daten hingegen wird in einem gesonderten Dokument beschrieben.

1.3 Qualitätsziele

Ziel	Beschreibung
Datenschutz	Im SwissHDS können die Verfahren zur Erkennung und Verhinderung von missbräuchlichen Zugriffen nur auf der Basis von Daten erfolgen, für deren Sammlung eine Rechtsgrundlage besteht, oder zu denen zweckgebundenen Nutzung die betroffenen Personen (Patientinnen und Patienten) eingewilligt haben.

1.4 Stakeholder

Stakeholder	Anmerkungen
BAG Architektur	Architekturboard des BAG.
Programm DigiSanté	Programm zur Förderung der Digitalisierung im Gesundheitswesen.
AG Datenraum	Arbeitsgruppe für die Architektur des Swiss HDS des DigiSanté Programms.
Anbieter von Services	Alle potenziellen Anbieter von Daten und Services im Datenraum Gesundheit.
Nutzer des Datenraums	Alle potenziellen Nutzer von Daten und Services im Swiss HDS bzw. die Hersteller der Primärsystem und Apps für Patientinnen und Patienten.

1.5 Typische Abläufe

1.5.1 Authentisierung von Benutzern

Benutzer authentisieren sich für Zugriffe auf API im Datenraum an einem, im Datenraum zugelassenen Identity Provider mit dem OpenID Connect Authorization Code Flow. Der OpenID Connect Authorization Code Flow ist ein etablierter internationaler Standard, auch in den EPDV spezifiziert und wird von den zertifizierten Identity Providern unterstützt (SwissSign, AGOV).

Daten über Anmeldungen, fehlgeschlagene Anmeldungen und Angriffsversuche werden von den Identity Providern erfasst. Diese Daten sind für die Basisdienste des Swiss HDS nicht direkt verfügbar und können nicht zur Erkennung und Verhinderung von missbräuchlichen Zugriffen verwendet werden.

1.5.2 Autorisierung von Zugriffen

Applikationen autorisieren sich für Zugriffe auf die API des Datenraums am Basisdienst Authorization Server auf der Control Plane. Sie senden dazu einen «Token Request» an den Authorization Server, welcher den Identity Token des authentifizierten Benutzers zusammen mit den fachlichen und administrativen Claims (z.B. Rolle des Benutzers) enthält.

Auf der Control Plane können dabei die folgenden Daten für die Erkennung und Verhinderung von missbräuchlichen Zugriffen erfasst werden:

- Identität des Benutzers – aus dem Open ID Connect Identity Token,
- Identity Provider – aus der digitalen Signatur des Identity Tokens,
- Identität der Applikation – aus dem OAuth Token des Token Request,
- Berechtigte und unberechtigte fachliche Claims (z.B. Rolle oder Institution) anhand der Daten aus dem Register bzw. Teilnehmerverzeichnis.

Zusätzlich können die folgenden Daten auf der Management Plane erfasst werden:

- Netzwerk, aus dem der Zugriff erfolgt.

Nach erfolgreicher Prüfung der Validität und der Claims stellt der Authorization Server einen Authorization Token (AuthZ) aus, der von den Clients bei allen Aufrufen der Services mitgesendet werden muss.

1.5.3 Zugriffsentscheide

Die API im Datenraum erhalten mit jedem Aufruf den Autorisierungstoken, der vom Authorization Server für den Zugriff durch die Applikation ausgestellt wurde. Das API nutzt die Informationen aus dem Autorisierungstoken zusammen mit den fachlichen und administrativen Daten aus der Anfrage zur Durchsetzung der Zugriffsrechte.

Dazu implementieren die API einen Policy Enforcement Point (PEP) gemäss dem XACML Standard (siehe 12.2). Das API extrahiert die Informationen aus dem Authorization Token, den Parametern der Anfrage und ggfs. weiteren Informationen und erstellt daraus einen XACML Request. Dabei enthalten die XACML Requests alle Attribute, welche für die Auswertung der Zugriffsrechte durch den Policy Decision Point (PDP) benötigt werden. Diese sind insbesondere

die Attribute, welche zur Auswertung der Einwilligung der betroffenen Personen (Patientinnen und Patienten) benötigt werden.

Bei korrekter Implementierung der API laufen daher die Informationen über alle Zugriffe im Datenraum im Basisdienst des Policy Decision Point (PDP) zusammen und der Policy Decision Point (PDP) entscheidet, ob der Zugriff erteilt werden kann, oder verwehrt werden soll.

Zur Erkennung und Verhinderung von missbräuchlichen Zugriffen, kann der Basisdienst des Policy Decision Point (PDP) weitere Informationen hinzuziehen, insbesondere:

- Statistische Daten und Muster der API Aufrufe des Benutzers, wie z.B. eine ungewöhnlich hohe Anzahl von Aufrufen der API im Datenraum durch den Benutzer.
- Statistische Daten und Muster der Aufrufe des API, wie z.B. eine ungewöhnlich hohe Anzahl vom Aufrufen eines speziellen API.
- Statistische Daten und Muster zu Versuchen einen Authorization Token mit bestimmten Claims beim OAuth Authorization Server zu beziehen.
- Statistische Daten und Muster des Aufbaus von Netzwerkverbindungen aus unerwarteten oder ungewöhnlichen Netzwerken.

Mit den o.g. Informationen können die Zugriffsentscheide des Policy Decision Point (PDP) Basisdienstes die Mittel und Methoden zur Analyse des Benutzerverhaltens (UBA) und Analyse des Benutzer- und Entitätsverhaltens (UEBA) anwenden, um missbräuchliche Zugriffe zu erkennen und mit negativen Zugriffsentscheidungen zu verhindern. Der Policy Decision Point (PDP) Basisdienst integriert sich damit in das Sicherheitsinformations- und Ereignismanagement (SIEM) der SwissHDS Basisdienste integrieren.

1.5.4 Rechtskonforme Protokollierung

Zugriffe auf Personendaten mit Schutzdarf müssen rechtskonform protokolliert werden, um nicht autorisierte Zugriffe auf Personendaten zurückverfolgen, die betroffenen Personen ermitteln und den potenziellen Schaden abschätzen zu können. Dazu werden im Datenraum alle Zugriffe entweder in einem zentralen Basisdienst oder lokal in den Systemen der Datenbereitsteller protokolliert.

Die rechtskonformen Protokolle enthalten aber keine Echtzeitdaten zur Erkennung und Verhinderung von missbräuchlichen Zugriffen, welche nicht schon anderen Quellen (wie z.B. dem Policy Decision Point Basisdienst) bekannt sind. Die Protokolldaten müssen daher nicht zur Erkennung und Verhinderung von missbräuchlichen Zugriffen herangezogen werden.

2 Randbedingungen

Stand 2025 sind die juristischen Rahmenbedingungen für den Datenaustausch im Swiss HDS noch nicht festgelegt. Das Dokument nutzt daher Annahmen auf dem Stand des besten Wissens zum aktuellen Zeitpunkt, insbesondere ähnliche oder gleiche Anforderungen aus dem EPDG und anderen bereits verabschiedeten Gesetzen.

3 Kontextabgrenzung

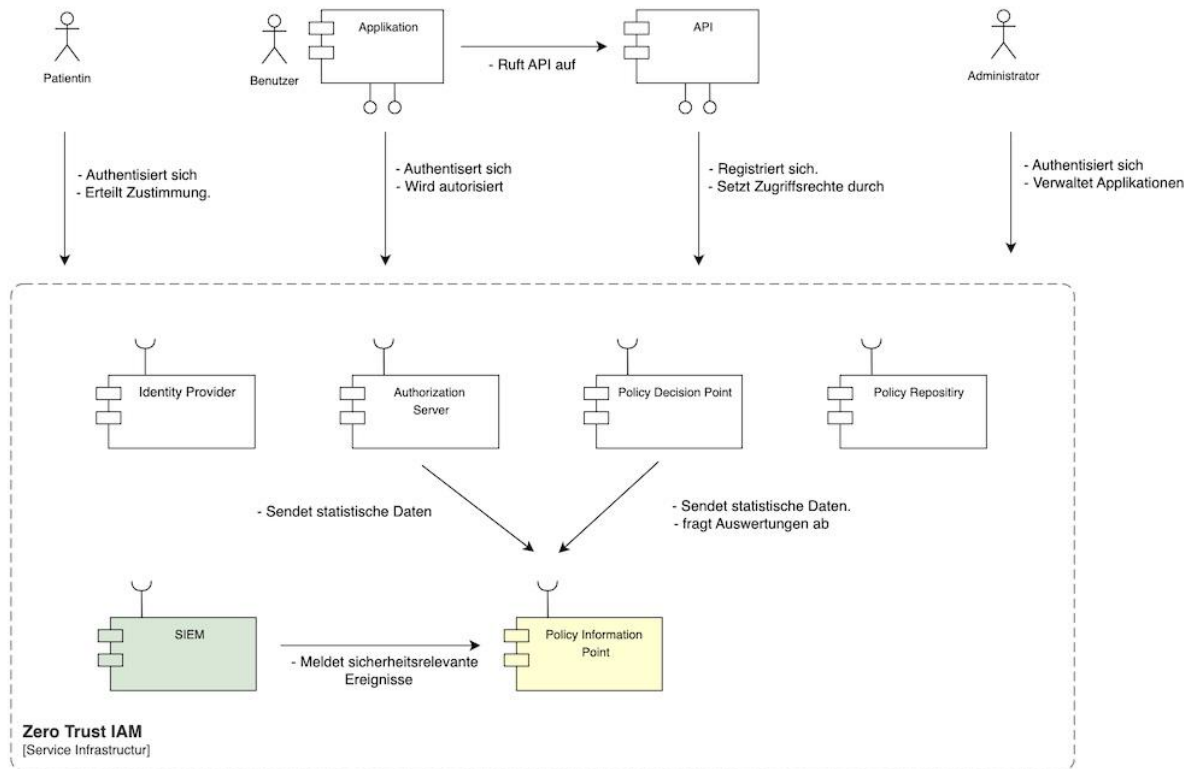


Abbildung 2: Kontextdiagramm des Zero Trust IAM im Swiss HDS

Abbildung 2 zeigt den Policy Information Point (PIP) Service zur Erkennung und Verhinderung von missbräuchlichen Zugriffen im Kontext des IAM³ und dem Sicherheitsinformations- und Ereignismanagement (SIEM) aus der Management Ebene des Swiss HDS.

Der Policy Information Point (PIP) Service sammelt Informationen aus den verfügbaren Quellen und bereitet diese für die Auswertung von Zugriffsentscheidungen durch den Policy Decision Point (PDP) auf.

³ «Swiss HDS IAM – Spezifikation für ein Identity und Access Management im Swiss HDS».

4 Lösungsstrategie

Herausforderung	Strategie
Policy Information	Die Logik zur Erkennung und Verhinderung von missbräuchlichen Zugriffen und die dazu benötigten Schnittstellen zum SIEM, Autorisation Server und Policy Decision Point (PDP) wird in einem Policy Information Point (PIP) Service implementiert.
RESTful API	In diesem Dokument wird angenommen, dass im Datenraum RESTful API für die Kommunikation genutzt werden.
Zugriffsentscheide	In diesem Dokument wird angenommen, dass die Zugriffsrechte auf der Ebene der Austauschformate (z.B. Medikationskarte, Impfausweis) durchgesetzt werden. Patientinnen und Patienten sollen dabei die Zugriffsrechte auf Austauschformate steuern können, wie z.B. den Zugriff auf ihre Medikationskarten aus dem CH EMED Standard für Benutzer, Institutionen, Forschungsprojekte, etc.
SIEM Integration	Zur Erkennung von missbräuchlichen Zugriffen soll der Policy Information Point (PIP) in das Sicherheitsinformations- und Ereignismanagement (SIEM) der SwissHDS Basisdienste integriert werden.
Standards	Aktuell existiert kein internationaler Standard für die Integration von SIEM oder anderer Quellen in den XACML Standard Flow für Zugriffsentscheide. Die Schnittstellen müssen im Rahmen des Umsetzungsprojekts spezifiziert werden.

5 Bausteinsicht

5.1.1 Policy Information Point (PIP)

5.1.1.1 Zweck und Verantwortung

Der Policy Information Point (PIP) sammelt statistische Daten und Ereignismeldungen aus dem Sicherheitsinformations- und Ereignismanagement (SIEM) der Basisdienste, dem Authorization Server und dem Policy Decision Point (PDP) und wertet die Daten zur Erkennung und Verhinderung von missbräuchlichen Zugriffen aus. Dazu bereitet der Policy Information Point (PIP) die Daten zweckgebunden aus und stellt die dem Policy Decision Point (PDP) zur Abfrage über eine Schnittstelle bereit, der Daten bei der Berechnung der Zugriffsentscheide hinzuzieht.

5.1.1.2 Schnittstellen

Zur Erfüllung des Zwecks implementiert der Policy Information Point (PIP) die folgenden Schnittstellen:

Schnittstelle	Beschreibung
SIEM Adapter	RESTful Schnittstelle für das Sicherheitsinformations- und Ereignismanagement (SIEM) der Basisdienste, über die sicherheitsrelevante Ereignisse an den Policy Information Point (PIP) gemeldet werden.
AuthN Adapter	RESTful Schnittstelle für den IAM Authorization Server, über die statistische Daten und sicherheitsrelevante Ereignisse an den Policy Information Point (PIP) gemeldet werden.
PDP Adapter	RESTful Schnittstelle für den Policy Decision Point (PDP), über die statistischen Daten und sicherheitsrelevante Ereignisse an den Policy Information Point (PIP) gemeldet werden.
PDP Interface	RESTful Schnittstelle über den der Policy Decision Point (PDP) die Daten für die Zugriffsentscheide abrufen kann.

5.1.1.3 Qualitäts- und Leistungsanforderungen

Anforderung	Erläuterung
Verfügbarkeit	Der Policy Information Point (PIP) soll 7*24 Stunden verfügbar sein.
Last	Der Policy Information Point (PIP) soll die erwartete Last ⁴ im Datenraum ohne nennenswerte Einschränkungen verarbeiten können.

⁴ Aktuell fehlen noch detaillierte Abschätzungen der zeitlichen Entwicklung der erwarteten Last.

Qualität	Die Programmlogik des Policy Information Point (PIP) soll eine hohe Rate bei der Erkennung von missbräuchlichen Zugriffen bei gleichzeitig kleiner Rate von «False Positives».

5.1.2 Offene Fragen

Keine.

6 Laufzeitsicht

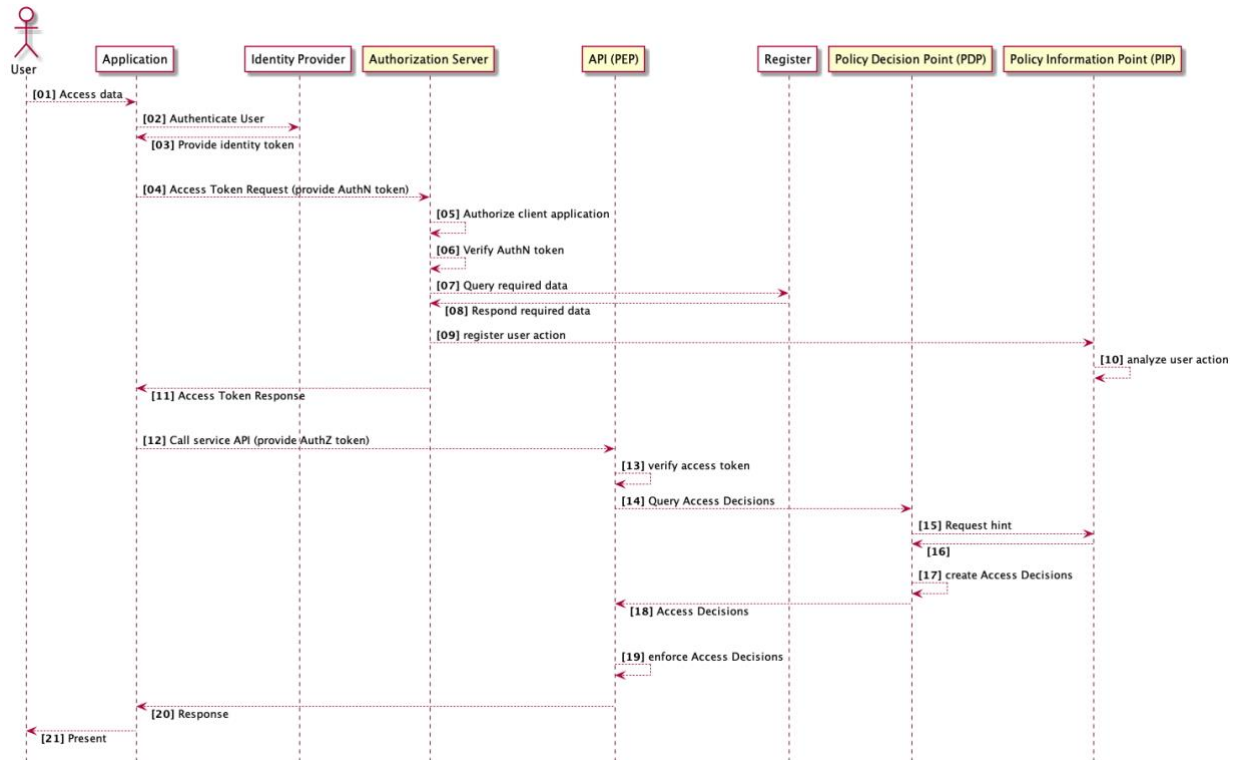


Abbildung 3: Sequenzdiagramm der Zero Trust Prozesse bei Zugriff auf die API im Datenraum.

Schritt	Beschreibung
1..3	Ein Benutzer authentisiert sich an einem anerkannten Identity Provider mit einem Verfahren zur starken Authentisierung mit seinem User Agent (z.B. Browser, UI des Primärsystems, native mobile App, usw.) seiner Applikation.
	Bei erfolgreicher Authentisierung sendet der Identity Provider einen Identity Token (AuthN Token) an die Applikation des Benutzers, bzw. an den User Agent, welcher den Identity Token an die Applikation weiterleitet.
4	Die Applikation sendet den Identity Token (AuthN Token) zusammen mit den fachlichen und administrativen Claims an den Authorization Server.
5..8	Der Authorization Server: • Identifiziert die Applikation anhand der Request Daten (Client ID, Client Secret, TLS Zertifikat, usw.). • Verifiziert, ob der Identity Token (AuthN Token) valide ist und von einem anerkannten Identity Provider ausgestellt wurde. • Verifiziert, ob die Applikation im Namen des authentisierten Benutzers auf die Services zugreifen darf (User Consent, Policy).

	• Fragt ggf. Register ab, um die für die Durchsetzung der Zugriffsrechte durch die API benötigten Attribute zu ermitteln. • Erstellt einen Autorisierungstoken (AuthZ Token) mit allen Informationen, welche für die Durchsetzung der Zugriffsrechte in den API benötigt werden.
9	Der Authorization Server registriert das Ereignis zur statistischen Auswertung an den Policy Information Point (PIP).
10	Der Policy Information Point (PIP) registriert das Ereignis, wertet es aus und nutzt die Auswertung zur Erkennung von ungewöhnlichen Verhalten.
11	Der Authorization Server signiert den Autorisierungstoken (AuthZ Token) und sendet ihn mit der Antwort an die Applikation des Benutzers.
12	Die Applikation des Datenkonsumenten sendet mit jeder Anfrage den Autorisierungstoken (AuthZ Token) im http Header der RESTful Transaktion zum Aufruf des API.
13	Das API des Datenbereitstellers validiert den Autorisierungstoken (AuthZ Token).
14	Das API nutzt die Informationen aus dem Autorisierungstoken, die Daten des Aufrufs und den Attributen der abgefragten Daten, bildet daraus einen XACML Authorization Request und fragt damit den Zugriffsentscheid am XACML Policy Decision Point (PDP).
15..17	Der XACML Policy Decision Point (PDP) nutzt die Informationen aus dem XACML Authorization Request und fragt den Policy Information Point (PIP) ab, ob für den Benutzer und die anfragende Applikation der Zugriff erteilt werden kann.
18	Der XACML Policy Decision Point (PDP) berechnet den Zugriffsentscheid anhand der Informationen aus dem XACML Authorization Request, den XACML Policies und des Policy Information Point (PIP).
19..20	Das API des Datenbereitstellers setzt den Zugriffsentscheid durch und sendet die Ergebnisse an die Applikation des Datenkonsumenten.
21	Die Applikation des Datenkonsumenten präsentiert die Daten aus dem Ergebnis dem Benutzer.

7 Verteilungssicht

8 Querschnitt Konzepte

Werden im Rahmen der Projektinitialisierung erstellt.

9 Architekturentscheide

Werden im Rahmen der Projektinitialisierung erstellt.

10 Qualitätsanforderungen

10.1 Qualitätsbaum

Wird im Rahmen der Projektinitialisierung erstellt.

10.2 Qualitätsszenarien

Werden im Rahmen der Projektinitialisierung erstellt.

10.3 Risiken und technische Schulden

Werden im Rahmen der Projektinitialisierung erstellt.

11 Glossar

Begriff	
OAuth 2.x	Standard für Web basierte Protokolle, die eine standardisierte, sichere API-Autorisierung für Desktop-, Web- und Mobile-Anwendungen erlauben.
OpenID Connect	Authentifizierungsschicht auf der Basis von Autorisierungsframework OAuth 2.0.
XACML	Ein XML und JSON basierter Sprachstandard für maschinenlesbare Sicherheitsrichtlinien (Policies), Zugriffsanforderungen und Zugriffsentschiede für eine auf Rollen- und Attribute basierende Zugriffssteuerung. Mit XACML Policies können administrative Zugriffsanforderungen und auf der Zustimmung von Patientinnen und Patienten abgeleitete Zugriffsanforderungen implementiert werden. Neben dem Sprachstandard definiert XACML eine Referenzarchitektur, die in Fachkreisen etabliert ist.
UBA und UEBA	Die Analyse des Benutzerverhaltens (User Behavior Analytics, UBA) oder die Analyse des Benutzer- und Entitätsverhaltens (User and Entity Behavior Analytics, UEBA) ist das Konzept der Analyse des Verhaltens von Benutzern, Subjekten, Besuchern usw. Es ermöglicht Cybersicherheitstools, ein Profil der normalen Aktivitäten jeder einzelnen Person zu erstellen, indem sie Muster des menschlichen Verhaltens untersuchen und dann Abweichungen von diesem Profil (oder Anomalien) hervorheben, die auf eine potenzielle Gefährdung hinweisen können. Dazu verwenden UBA-Tools eine spezielle Art der Sicherheitsanalyse, die sich auf das Verhalten von Systemen und den Menschen, die sie nutzen, konzentriert.
SIEM	Sicherheitsinformations- und Ereignismanagement (SIEM) ist ein Bereich der Computersicherheit, der Sicherheitsinformationsmanagement (SIM) und Sicherheitereignismanagement (SEM) kombiniert, um eine Echtzeitanalyse von Sicherheitswarnungen zu ermöglichen, die von Anwendungen und Netzwerkhardware generiert werden. SIEM-Systeme spielen eine zentrale Rolle in Sicherheitsoperationszentren (SOCs), wo sie zur Erkennung, Untersuchung und Reaktion auf Sicherheitsvorfälle eingesetzt werden.

IDS	Ein Intrusion Detection System (IDS) ist ein Gerät oder eine Softwareanwendung, die ein Netzwerk oder Systeme auf böswillige Aktivitäten oder Richtlinienverstöße überwacht. Jede Intrusionstätigkeit oder jeder Verstoß wird in der Regel entweder einem Administrator gemeldet oder zentral mithilfe eines Security Information and Event Management (SIEM)-Systems erfasst.
EDR	Endpoint Detection and Response (EDR), auch bekannt als Endpoint Threat Detection and Response (ETDR), ist eine Cybersicherheitstechnologie, die einen „Endpunkt“ (z. B. ein Client-Gerät wie ein Mobiltelefon, einen Laptop oder ein IoT-Gerät) kontinuierlich überwacht, um böswillige Cyberbedrohungen abzuwehren.

12 Anhang

12.1 Risikoabschätzung

12.1.1 DOS Angriffe

Ein Denial of Service Angriff (DOS) oder Distributed Denial of Service Angriff (DDoS) ist ein Angriff auf das Schutzziel der Verfügbarkeit der SwissHDS Basisdienste. Denial of Service (DOS) Angriffe werden mittlerweile professionell durchgeführt und können schon ab wenigen tausend Dollar im Darknet beauftragt werden.

Bei DOS-Angriffen flutet der Angreifer die Ziele mit Anfragen und überlastet dadurch die Services bzw. die Netzwerkinfrastruktur. Die Services können dann reguläre Anfragen nicht mehr bearbeiten und falls praktisch aus. Bei DDoS Angriffen werden die DOS Attacken von sehr vielen verschiedenen Netzwerken ausgeführt, wodurch diese schwieriger geblockt werden können. Aufwendige DDoS Angriffe können Services für Stunden oder Tage blockieren.

Häufige Ziele für DOS Attacken sind Single Point of Failure Services, da sich die Angriffe auf das ganze Netzwerke auswirken. In der Zero Trust Architektur des SwissHDS sind dies insbesondere:

- OAuth Authorization Server,
- Policy Decision Point (PDP).

Wegen der Häufigkeit von DOS Angriffen haben sich effektive Massnahmen etabliert, wie z.B. Sperrung von IP Adressen, Host Korrelation⁵, etc. Die Massnahmen werden auf der Basis von Daten ergriffen, welche auf der Management Ebene erfasst werden und werden auch auf der Management Ebene durchgesetzt.

Zero Trust Architekturen sind bekannt für die Anfälligkeit bei DOS Angriffen. Dies gilt auch für die Zero Trust Architektur des SwissHDS. Im Rahmen der Umsetzung müssen mögliche Massnahmen evaluiert und nach den Kriterien der Wirksamkeit ausgewählt werden.

12.1.2 Phishing

Unter dem Begriff Phishing sind Angriffe zusammengefasst, welche sich über gefälschte Webseiten, E-Mails oder Kurznachrichten als vertrauenswürdig ausgeben um an persönliche Daten eines Internet-Benutzers zu gelangen, insbesondere die Login Credentials, um diese zur Authentisierung zu nutzen. Phishing Angriffe werden heute ebenfalls professionell durchgeführt und können mit Toolkits aus dem Darknet leicht erstellt werden.

Phishing Angriffe sind häufig das Einfallstor für viele andere Angriffe. Mit dem erschlichenen Login Credentials hat der Angreifer Zugriff auf Daten mit Schutzbedarf und kann diese missbrauchen. Besonders schwerwiegend sind Phishing Angriffe bei dem es dem Angreifer gelingt, die Login Credentials von Administratoren auf der Management Ebene zu erschleichen und Einfallstore oder Schadsoftware zu installieren.

Phishing ganz zu unterbinden gilt in Sicherheitskreisen als unmöglich. Gegenmassnahmen konzentrieren sich daher den potentiellen Schaden zu minimieren. Die konsequente

⁵ Host Korrelation ist eine Gegenmassnahme gegen gleichzeitige Angriffe aus verschiedenen Netzen, bei der anhand der statistischen Daten die Hosts ermittelt werden, welche wahrscheinlich an einem Angriff mitwirken.

Umsetzung der Zero Trust Prinzipien gilt aktuell als das wirkungsvollste Massnahmenpaket, insbesondere

- 2 Faktor Authentisierung auf hoher Sicherheitsstufe mit 2 unabhängigen Faktoren,
- Treffen der Zugriffentscheide möglichst nahe an den Ressourcen mit Schutzbedarf,
- Erkennen von ungewöhnlichen Verhalten.

In der Zero Trust Architektur des SwissHDS sind die o.g. Massnahmen adressiert. Im Rahmen der Umsetzung muss darauf geachtet werden, dass die Massnahmen ohne Ausnahmen umgesetzt werden, insbesondere auch auf Zugriffe der Administratoren auf der Management Ebene.

Um den potenziellen Image Schaden zu minimieren, müssen besondere Massnahmen zum Schutz des Policy Repository und des Protokoll Service gegen Ransomware Angriffe getroffen werden.

12.1.3 Ransomware

Ransomware sind Schadprogramme, mit deren Hilfe ein Angreifer den Zugriff auf die Daten von Diensten verhindern kann. Dabei werden persistente Daten des Dienstes verschlüsselt oder der Zugriff auf sie anderweitig verhindert, um für die Entschlüsselung oder Freigabe ein Lösegeld zu fordern. Phishing Angriffe werden heute ebenfalls professionell durchgeführt und können mit Toolkits aus dem Darknet leicht erstellt werden.

In der Zero Trust Architektur des SwissHDS kann potenzieller Schaden durch Ransomware Angriffe im Policy Repository und dem Protokoll Service entstehen. Bei Angriffen auf das Policy Repository können potenziell alle Daten verlorengehen, welche für die Auswertung von Zugriffsrechten benötigt werden, insbesondere der Consent der Patientinnen und Patienten. Obwohl damit keine missbräuchlichen Zugriffe ermöglicht werden, wäre der potenzielle Image Schaden für SwissHDS beträchtlich.

Bei Angriffen auf den Protokoll Service gehen potenziell alle Protokoll Daten verloren, welche für die forensische Analyse im Rahmen von Strafverfahren benötigt werden. Obwohl damit ebenfalls keine missbräuchlichen Zugriffe ermöglicht werden, wäre der potenzielle Image Schaden für SwissHDS beträchtlich.

12.1.4 Replay Angriffe

Eine Replay-Attacke ist ein Angriff, bei dem ein Angreifer Autorisierungsdaten während der Kommunikation abfängt und erneut überträgt, um den Empfänger vorzuspiegeln, dass es sich um autorisierte Zugriffe auf Daten mit Schutzbedarf handelt.

Wegen der Häufigkeit der Angriffe haben sich geeignete Massnahmen etabliert, insbesondere:

- Reduktion der Lebensdauer von Autorisierungstoken, damit diese nicht ange wiederverwendet werden können.
- Verwendung von sicheren und verschlüsselten Kommunikationsprotokollen, um die Daten während der Übertragung gegen unautorisierten Zugriff zu schützen.
- Einschränkung des Anwendungsbarkeit von Token für dedizierte Endpunkte.

Die konsequente Umsetzung dieser Massnahmen sichert das System gegen Token Replay Angriffe auf dem aktuellen Stand der Technik.

12.1.5 OAuth Angriffe

Die Zero Trust Architektur des SwissHDS nutzt den OAuth Client Credential Flow mit den Erweiterungen aus RFC 7523. Neben dem Token Replay sind weitere Angriffe auf OAuth basierte Systeme bekannt, welche zusammen mit geeigneten Massnahmen zur Verhinderung im OAuth 2.0 Protocol Cheatsheet⁶ beschrieben sind.

Die konsequente Umsetzung dieser Massnahmen sichert das System gegen die bekannten Angriffe auf dem aktuellen Stand der Technik.

12.2 XACML Referenzarchitektur

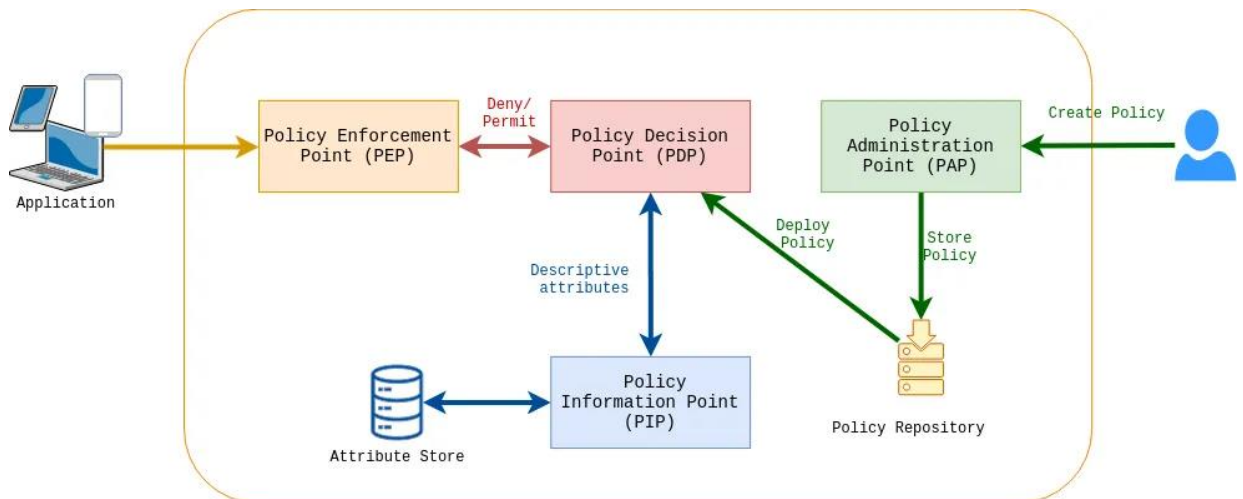


Abbildung 4: XACML Referenzarchitektur

⁶ https://cheatsheetseries.owasp.org/cheatsheets/OAuth2_Cheat_Sheet.html